

INCIDENT REPORT 1

=====

Report ID: IR-001
Incident Name: SSH Brute Force / Password Guessing Attempt
Date/Time: May 5, 2026, around 09:24–09:25
Severity: HIGH
Status: Resolved (lab environment)
Environment: Wazuh 4.7.5 Mini SOC Home Lab
Analyst: Jazz

1. EXECUTIVE SUMMARY

At approximately May 5, 2026 around 09:24–09:25, Wazuh SIEM detected repeated SSH authentication failures in the lab environment. The activity involved invalid usernames and incorrect password attempts against a Linux SSH service. Wazuh generated authentication-related alerts including “sshd: Attempt to login using a non-existent user,” “PAM: User login failed,” and “User missed the password more than one time.”

This activity simulated a brute-force/password-guessing attack, where an attacker repeatedly attempts to guess valid SSH credentials. In this controlled lab, the activity was intentionally generated to test Wazuh’s ability to detect credential access behavior. The alert was confirmed as a true positive in a lab environment.

The incident was mapped to MITRE ATT&CK Technique T1110.001 — Brute Force: Password Guessing under the Credential Access tactic.

2. TIMELINE

May 5, 2026 around 09:24:50

First visible SSH authentication failure / invalid user attempt appears in Wazuh Security Events.

May 5, 2026 around 09:25:05

Additional SSH login attempts were detected using invalid usernames and wrong passwords.

May 5, 2026 around 09:25:11

Wazuh generated repeated “sshd: Attempt to login using a non-existent user” alerts.

May 5, 2026 around 09:25:13

Wazuh generated a higher-severity authentication alert: “User missed the password more than one time.”

May 5, 2026 around 09:25

The alert appeared in the Wazuh Security Events dashboard and was reviewed by the analyst.

May 5, 2026 after alert review

The event was confirmed as a true positive lab simulation. No real compromise occurred.

3. DETECTION SOURCE

Tool: Wazuh SIEM/XDR
Wazuh Version: 4.7.5
Detection Area: Linux SSH authentication monitoring
Log Source: Linux /var/log/auth.log and Wazuh Security Events
Protocol: SSH
Destination Port: 22

Observed Wazuh Rule IDs:

- 5710 — sshd: Attempt to login using a non-existent user
- 5503 — PAM: User login failed
- 2502 — User missed the password more than one time

Severity:

- Rule 5710: Level 5
- Rule 5503: Level 5
- Rule 2502: Level 10

Affected Agent:

- Wazuh-Server shown in the main alert screenshot
- Similar SSH brute-force testing was also performed against ubuntu-endpoint

Target System:

- Linux SSH service in the Wazuh lab environment

4. MITRE ATT&CK MAPPING

Tactic: Credential Access
Technique: Brute Force
Sub-technique: T1110.001 — Password Guessing

Explanation:

The activity maps to Credential Access because the attacker attempted to guess or validate credentials through repeated SSH login attempts. Password guessing is a common brute-force technique used to gain unauthorized access to systems.

Potential attacker next steps if successful:

- Gain initial access to the Linux system
- Run reconnaissance commands
- Attempt privilege escalation using sudo
- Modify system files or create persistence
- Move laterally to other systems in the network

5. INVESTIGATION FINDINGS

Source:

The source IP should be taken from the expanded Wazuh alert or /var/log/auth.log. In the current screenshot evidence, the report notes that the source IP is visible in the raw log/auth.log when expanded.

Target:

Linux SSH service on the monitored lab endpoint.

Targeted usernames:

- wronguser
- enduser

Observed behavior:

- SSH login attempts were generated using invalid usernames.
- Wrong passwords were entered during the test.
- Wazuh generated multiple SSH/PAM authentication alerts.
- The activity appeared in the Wazuh Security Events dashboard.
- The event was mapped to MITRE ATT&CK T1110.001 Password Guessing.
- No successful login was confirmed after the failed attempts.

Evidence reviewed:

- Wazuh Security Events table showing brute-force/multiple failed login alerts
- Expanded alert details showing SSH/PAM-related fields
- Ubuntu auth.log terminal evidence showing invalid user/authentication-related logs
- Hydra SSH test evidence showing password attempts against the Ubuntu endpoint
- MITRE ATT&CK mapping showing T1110.001 Password Guessing

Account locked:

No. Account lockout policy was not configured in the lab.

Compromise confirmed:

No. The activity was a controlled simulation and there was no confirmed successful login from the same attack sequence.

6. RISK ASSESSMENT

Risk: HIGH

Reason:

Repeated SSH authentication failures indicate password-guessing behavior. If the attacker guesses a valid password, they could gain unauthorized access to the Linux system. Once inside, the attacker could perform reconnaissance, attempt sudo privilege escalation, access sensitive files, create persistence, or move laterally to other hosts.

The risk is especially high if:

- Password authentication is enabled for SSH
- Weak or reused passwords are used
- No account lockout or rate limiting is configured
- SSH is exposed to untrusted networks
- MFA or SSH key-only authentication is not enforced

In this lab, the risk was controlled because the attack was intentionally generated and no successful compromise occurred.

7. VERDICT

Verdict: TRUE POSITIVE — Lab Simulation

The alert is a true positive because the suspicious activity actually occurred. The SSH login attempts were intentionally generated in the lab, and Wazuh correctly detected them as authentication failure and password-guessing behavior.

This was not a false positive because the logs clearly show repeated invalid login behavior. However, because the activity was performed in a controlled lab environment, no production incident or real compromise occurred.

8. RESPONSE ACTIONS TAKEN

1. Reviewed the Wazuh Security Events dashboard.
2. Opened the brute-force related alerts.
3. Verified the rule IDs and severity levels.
4. Checked the affected agent and log source.
5. Reviewed terminal/auth.log evidence for SSH authentication failures.
6. Confirmed the MITRE ATT&CK mapping to T1110.001 Password Guessing.

7. Confirmed the event as a lab-generated true positive.
8. Documented the incident for SOC triage/reporting practice.

9. RECOMMENDATIONS

1. Enable account lockout policy where possible.
Example: lock account after 5 failed attempts for 30 minutes.
2. Disable password-based SSH login and use SSH key-based authentication.
3. Restrict SSH access to trusted IP addresses only.
4. Install and configure fail2ban on Linux systems to automatically block repeated failed SSH attempts.
5. Monitor for successful logins after failed login attempts.
6. Review `/var/log/auth.log` regularly for invalid user attempts and repeated authentication failures.
7. Create Wazuh alerts or dashboards specifically for repeated SSH authentication failures.
8. Enable Wazuh Active Response to temporarily block suspicious source IPs.
9. Enforce strong password policies and prevent password reuse.
10. Investigate whether the same source IP attempted access against other systems in the network.

10. FINAL ANALYST NOTE

This incident demonstrates the core SOC workflow of detecting, investigating, and documenting a brute-force/password-guessing attempt. Wazuh successfully collected Linux authentication logs, generated alerts, assigned severity levels, mapped the activity to MITRE ATT&CK, and provided enough evidence for analyst triage. This confirms that the Mini SOC lab is capable of detecting credential access behavior across Linux endpoints.